

5 Manage Identities and Separate Privileges

5.1 Logical Access Control

Control Type: Mandatory	Applies to architecture:	A1	A2	A3	A4	B
		•	•	•	•	•
<u>Control Definition</u> Control Objective: Enforce the security principles of need-to-know access, least privilege, and separation of duties for operator accounts. In-scope components: User, operator or management accounts defined on the following components: • on-premises or remote virtualisation or cloud platform and their management PCs, hosting Swift-related VMs, including those hosting the Alliance Connect Virtual on Premises VPN, and on those VMs themselves • jump server • dedicated operator PCs • operating systems hosting interfaces, GUI, Swift and customer (client) connectors, Swift connectivity provider or outsourcing agent Swift-related applications • interfaces, GUI, connectors, Swift connectivity provider or outsourcing agent Swift-related applications • customer client connector and the operating system hosting it • HSM • network devices protecting the secure zone or the customer client connectors • SwiftNet Online Operations Manager (O2M), a Swift Web Access service and the Secure Channel service on swift.com • All operator accounts on the bridging servers (such as middleware or file transfer servers other than customer connectors), used for and guardian of the secure data exchange between back-office and Swift-related components Note: Sharing/reusing credentials and roles/entitlements (accounts) for business transactions on other systems or components used for ancillary services will turn those systems or components in scope of the CSCF controls. Risk Drivers: • excess privilege or access • separation of duty violation • unauthorised access • HSM management misused						
<u>Implementation Guidance</u> Control Statement: Accounts are defined according to the security principles of need-to-know access, least privilege, and separation of duties. Control Context: Applying the security principles of (1) need-to-know, (2) least privilege, and (3) separation of duties is essential to restricting access to the user's Swift infrastructure. Effective management of operator accounts reduces the opportunities for a malicious person to use these accounts as part of an attack. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's						

implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives).

A logical access control policy is documented and enforced based on the following principles:

- Need-to-know.
 - Only operators (end users and administrators) who have a continuing requirement to access the secure zone are permitted to have accounts within the secure zone.
 - Privileges are only assigned to an operator with a validated need-to-know (for example, system set-up makes sure that operators only have access to the information, files, and system resources necessary for their defined tasks). Access to other system functions is disabled.
- Least Privilege.
 - The system set-up makes sure that user and administrator privileges are controlled in a way that allows all privileges to be tailored to individual needs.
 - Accounts are granted only to privileges that are required for normal, routine operation. Additional privileges are only granted on a temporary basis.
- Separation of Duties and Four-Eyes.
 - Vendor documented guidance on role separation is followed in vendor-specific documentation.
 - Sensitive duties are separated. This means that some roles cannot be represented by the same individual, such as:
 - Transaction submission and transaction approval
 - Application Administrator and security officer roles
 - Network and operating system administrators.
 - Sensitive permissions are separated to prevent by-passing the Four-Eyes principle. At a minimum, this requirement applies to access control and security configuration operations on the following components: Messaging and Communication Interface, GUI, Swift and customer connectors, Swift connectivity provider or outsourcing agent Swift-related applications, HSMS, SwiftNet Online Operations Manager, and Secure Channel.
- Account Review and Revocation
 - Privileges (including those delegated to providers) are promptly revoked when an employee changes roles or leaves the organisation (or the provider). Privileges assignment must ensure continuous accountability and traceability.
 - Accounts (including those delegated to providers) are reviewed at least annually and adjusted as required to continuously ensure accountability and traceability of accounts assignment.
- An emergency procedure to access privileged accounts is documented for use when authorised people are unavailable due to unexpected circumstances:
 - Any operational use of the procedure is logged.
 - Access to the emergency privileged accounts is controlled. Usage is logged, in line with or as part of the control 6.4, ensuring accountability and traceability and the password is changed after emergency use.

Optional Enhancement:

- Apply the control to the operator accounts on all the bridging servers (such as middleware or file transfer servers other than customer connectors) used for data exchange between back-office and Swift-related components.